

Administrative Control Plan

Step 1

Select one administrative control that you want to create a plan for from the following list:

- Training
- Job rotation
- Mandatory vacation

Step 2

Create a plan that addresses the role of that control in protecting the company's data and infrastructure. The following list details topics that you should cover based on the control you choose.

Training

- Explain the cybersecurity onboarding training that employees will take.
- Explain how often employees must complete additional cybersecurity training. Justify your response.
- Describe how you would inform employees about new cyberthreats.

Job rotation

- Explain how you will cross-train employees so that they can rotate tasks.
- Identify the number of people that will share responsibilities to ensure accountability. Justify your answer.
- Indicate if you will swap job tasks or roles that involve accessing confidential data. Explain your answer.

Mandatory vacation

- Explain the use of mandatory vacation policies.
- Describe the controls you will implement so that when an employee is on vacation for at least five days, their tasks and role in cybersecurity are covered.
- Justify whether you would enact a mandatory vacation policy as an administrative control.

Cybersecurity Training Program

Control Selected: Training

Objective:

The purpose of this cybersecurity training program is to educate employees on security best practices and reduce the risk of cyber incidents caused by human error and ensure compliance with industry frameworks (e.g., ISO 27001, NIST SP 800-53). Proper training helps protect the company's data, systems, networks, and infrastructure from threats such as phishing, malware, social engineering, and unauthorized access.

1. Cybersecurity Onboarding Training

All new employees, regardless of department or seniority- must complete *cybersecurity onboarding training* during their first week of employment. prior to receiving access to elevated permissions or sensitive systems. The training will cover:

- Information Security Policies and Procedures
- Password Management and Multi-Factor Authentication (MFA)
- Phishing and Social Engineering Awareness
- Safe Email and Internet Usage
- Data Classification and Handling Procedures
- Secure Use of Company Devices
- Remote Work Security Practices
- Incident Reporting Procedures
- Physical Security Requirements
- Privacy and Confidential Data Protection

1.1: Generative AI Acceptable Use Policy (AUP) & Shadow AI Training.

A. Permitted vs. Prohibited AI Usage (ISO 42001 A.2):

- **Mandatory Training Module:** Clear guidelines for using public GenAI tools (ChatGPT, Claude, Gemini, Copilot).
- **Rule:** Prohibit pasting proprietary code, customer Personally Identifiable Information (PII), or unreleased financial data into public AI prompts without corporate enterprise agreements

B. Human-in-the-Loop (HITL) Validation Requirement:

- Mandate that all employee output generated by AI (code, reports, legal/compliance text) undergo mandatory human verification prior to client delivery or system deployment.

Employees must successfully complete a knowledge assessment before receiving full access to company systems.

2. Frequency of Additional Cybersecurity Training

Employees will complete mandatory cybersecurity awareness training every three months

Justification

Cyber threats evolve rapidly, and employees need regular updates to remain aware of new attack methods. Quarterly training:

- a. Reinforces secure behaviors.
- b. Reduces the likelihood of successful phishing attacks.
- c. Ensures compliance with security policies.
- d. Keeps employees informed about emerging threats and vulnerabilities.
- e. Improves the organization's overall security posture.

In addition, annual comprehensive cybersecurity certification training will be required for all employees.

3. Informing Employees About New Cyber Threats

The organization will use multiple communication channels to keep employees informed about emerging cyber threats:

Security Alerts

The Information Security Team will distribute email alerts whenever significant threats are identified.

Monthly Security Bulletins

A cybersecurity newsletter will summarize:

- Recent threats
- Industry security incidents
- Security best practices
- Lessons learned from internal incidents
- Security Awareness Portal

Employees will have access to an internal security portal containing:

- Threat advisories
- Training materials
- Security policies
- Incident reporting guidance
- Simulated Phishing Campaigns

Periodic phishing simulations will test employee awareness and provide immediate educational feedback.

Emergency Notifications

For critical threats, immediate notifications will be sent through email, company messaging platforms, and SMS alerts when necessary.

AI Phishing & Deepfake Awareness

- Threat Communication: Add AI-generated deepfake audio/video and personalized LLM-driven phishing lures to your quarterly simulation programs.

Conclusion

A comprehensive cybersecurity training program is a critical administrative control that strengthens the organization's security posture. By providing onboarding training, conducting quarterly awareness sessions, and communicating emerging threats promptly, the company can significantly reduce cybersecurity risks and better protect its data and infrastructure.